

AI Tool and Agent Sprawl 2026 Media Brief

Public AI Adoption Is Easy to See. Governed Use Is Still Hard to Prove.

- Run ID: sprawl-v2-top250-20260508a
- Scope: locked 250-target public GitHub cohort (125 AI-native, 75 developer-platform, 50 security-platform)
- Study design: deterministic baseline, one repository per owner, local clone-sourced artifacts

The Short Version

CAISI measured public AI tool and agent governance posture across a locked 250-target GitHub cohort. The strongest result is not that public repositories hide all deployment signal. They do not. The strongest result is that public repositories often show AI use and even deployment evidence before they show clean approval proof and complete binding evidence.

In the cohort, 91.6% of targets declared at least one agent and 88.0% showed at least one deployed-agent signal. But 100% of detected agents were missing at least one declared binding, 54.4% of targets lacked verifiable governance evidence, and non-source AI tools outside the baseline-approved set still outnumbered baseline-approved tools 5.64:1.

The report is explicit about what it does and does not prove. It is a public-repository visibility study, not a production-runtime exploit census. Public 0% values for production-write should not be read as internal safety guarantees. The key governance result is that detection now outruns proof in a more operationally meaningful way than before.

The named proxy controls are narrow: EU AI Act uses Article 9 Risk Management, Article 12 Record-Keeping, and Article 14 Human Oversight; SOC 2 uses CC6 Logical Access, CC7 System Operations, and CC8 Change Management; PCI DSS uses Requirement 10 Logging and Monitoring.

The run can say something about public governance evidence for EU AI Act, SOC 2, and PCI DSS proxies. It does not support broader claims for frameworks outside the current v2 headline-eligible mapping set.

Headline Findings

- 229 of 250 targets (91.6%) declared at least one agent.
- Average declared agents per target: 8.89.
- 220 of 250 targets (88.0%) showed deployed-agent signal.
- 2222 of 2222 detected agents were missing at least one declared binding.
- 136 of 250 targets (54.4%) lacked verifiable governance evidence.
- Non-source AI tools outside the baseline-approved set outnumbered baseline-approved tools 5.64:1 (1845 to 327).
- 226 of 250 targets (90.4%) showed an EU AI Act Article 50 transparency-proxy gap.
- 16 of 250 targets (6.4%) exposed write-capable agents in public artifacts.
- 17 of 250 targets (6.8%) exposed exec-capable agents in public artifacts.
- 45 of 250 targets (18.0%) exposed credential-access agents in public artifacts.

Why This Matters

For AppSec teams, the report shows that public repositories now often expose enough deployment signal to justify deeper review, but still not enough binding evidence to support clean authority claims. For CISOs, the approval ratio remains a proof gap: visible AI use without durable machine-readable approval evidence. For platform leaders, deployment markers without tool, data, and auth bindings are not a mature operating model.

The practical governance lesson is simple: discovery matters, deployment evidence matters, but approval

records and binding completeness have to mature with adoption. Otherwise organizations can detect AI use without being able to defend, review, or explain it cleanly.

Scope And Limits

- This is a locked 250-target public cohort, not a private runtime study.
- One target hit a scanner parser failure and was carried fail-closed into the aggregate.
- Public repositories underexpose private runtime privilege, credentials, and internal approval workflows.
- Regulatory outputs are deterministic readiness proxies, not legal conclusions.

Links

- [Full report PDF](#)
- [Media brief PDF](#)
- [Report page](#)
- [Report package](#)
- [Run artifacts](#)
- david@caisi.dev